COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.3 · OS Vulnerabilities

Mestre CyberSec · **Aula 2.3 — OS Vulnerabilities** (4:09) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Falha no sistema operacional (kernel, serviços, bibliotecas). Windows tem Patch Tuesday — dezenas de correções por mês. SO sem patch = alvo fácil. Zero-day OS = sem correção disponível. Defesa: patch ASAP, EDR.

💡 Highlights que a prova CompTIA cobra

- Patch Tuesday: Microsoft corrige dezenas de CVE por mês
- Legacy (XP): sem suporte, sem patch — desativar/segmentar

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'operating system lacks patches' = legacy/unsupported OS vulnerability

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.3 — OS Vulnerabilities)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Patch Tuesday (Terça de Atualizações)

Lançamento mensal de atualizações de segurança da Microsoft, na segunda terça-feira de cada mês, corrigindo tipicamente dezenas de CVEs no Windows e softwares relacionados. Um SO sem patch entre os ciclos é um alvo fácil de exploração.

⚠ ***Armadilha CompTIA:*** *Trigger: 'second Tuesday of the month' or 'dozens of monthly Microsoft fixes' = Patch Tuesday. Key distinction: Patch Tuesday = scheduled release cycle; out-of-band/emergency patch = critical fix released at any time outside the cycle.*

• Vulnerabilidade Zero-Day

Vulnerabilidade desconhecida do fabricante ou divulgada publicamente sem patch disponível, deixando zero dias para reação. Zero-days de SO são graves pois a exploração atinge o kernel e todos os serviços em execução.

⚠ ***Armadilha CompTIA:*** *Trap: zero-day = NO patch exists; 'unpatched/missing patches' = patch exists but was not applied. If the stem says 'no fix is available', answer zero-day, not legacy OS.*

• Sistema Operacional Legado

SO antigo que não recebe mais patches de segurança do fabricante (ex.: Windows XP), permanecendo permanentemente vulnerável a exploits conhecidos. A mitigação exige substituição ou, quando impossível, isolamento da rede.

⚠ ***Armadilha CompTIA:*** *Direct exam trigger from this lesson: 'operating system lacks patches' = legacy/unsupported OS vulnerability. Mitigation order: upgrade/replace first → segment/isolate if it cannot be replaced. Don't pick 'install antivirus' as the full answer.*

• Fim de Vida (EOL)

Data declarada pelo fabricante a partir da qual o produto deixa de receber qualquer atualização ou suporte; software EOL deve ser desativado ou fortemente segmentado, pois nunca mais será corrigido.

⚠ ***Armadilha CompTIA:*** *Distinction: EOL = vendor permanently stopped support; 'not yet patched' = updates exist but are pending. EOL device in a question → segment or replace, and treat it as unfixable.*

• Detecção e Resposta em Endpoint (EDR)

Solução que monitora continuamente endpoints, detectando e respondendo a atividades suspeitas baseadas em processo e comportamento nos sistemas operacionais — o principal controle compensatório quando o patching está

atrasado ou impossível.

⚠️ ***Armadilha CompTIA:*** *Distinction: EDR = behavioral detection with response actions (isolate host, remove threat); signature-based anti-malware = known threats only. Expect EDR paired with zero-day or legacy OS scenarios in this lesson.*

• Vulnerabilidades e Exposições Comuns (CVE)

Catálogo mantido pelo MITRE, no formato CVE-AAAA-NNNN, que identifica de forma única vulnerabilidades divulgadas publicamente; avisos do fabricante e o Patch Tuesday referenciam esses IDs.

⚠️ ***Armadilha CompTIA:*** *Distinction: CVE names/identifies the vulnerability; CVSS (0.0–10.0) scores its severity; NVD is the searchable database of CVEs. Don't swap CVE and CVSS in an answer.*

• Segmentação (de Rede)

Controle de arquitetura de rede que isola sistemas legados ou sem possibilidade de patch em segmentos restritos com firewalls/ACLs, contendo o comprometimento do SO para que não se espalhe lateralmente.

⚠️ ***Armadilha CompTIA:*** *Exam pairing: legacy/EOL OS that 'cannot be replaced' → segmentation or isolation is the best available control. Distinction: segmentation = logical isolation with rules; air gap = full physical separation.*

• Núcleo do Sistema (Kernel)

Componente central do sistema operacional que gerencia memória, processos e acesso ao hardware; uma vulnerabilidade no kernel compromete o sistema inteiro, pois todo serviço e biblioteca depende dele.

⚠️ ***Armadilha CompTIA:*** *Hierarchy from this lesson: kernel (core) → services → shared libraries — a flaw in any layer = OS vulnerability. Kernel-level compromise means the highest impact, typically root/system privileges.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa possui um grande parque de estações de trabalho e servidores Windows. O diretor de TI quer uma janela mensal previsível de manutenção para atualizações de segurança do sistema operacional Microsoft, permitindo ainda um curto período de testes antes da implantação em produção. Qual prática de gerenciamento de patches atende melhor a esse requisito?

A) Aplicar atualizações de segurança do SO Microsoft na segunda terça-feira de cada mês após validá-las em um grupo de teste.

B) Aplicar atualizações do SO somente quando um novo CVE for publicado para o sistema operacional.

C) Permitir que os usuários adiem indefinidamente todas as atualizações do SO até relatarem problemas de desempenho.

D) Aplicar patches somente em sistemas que já apresentaram sinais de comprometimento.

QUESTÃO 2 · CENÁRIO DE EXAME

A inteligência de ameaças informa que uma vulnerabilidade zero-day no kernel do sistema operacional está sendo explorada ativamente. Ainda não há patch do fornecedor. Qual ação a equipe de segurança deve tomar primeiro?

A) Esperar a próxima Patch Tuesday programada e confiar nas assinaturas de antivírus existentes até então.

B) Desabilitar o módulo de kernel afetado em todos os sistemas, incluindo os críticos para o negócio, sem testes.

C) Habilitar detecção comportamental via EDR e implantar controles compensatórios, como hardening e restrições de rede.

D) Reinstalar a imagem de todos os endpoints da organização imediatamente, incluindo os não afetados.

QUESTÃO 3 · CENÁRIO DE EXAME

Uma planta de manufatura usa um SO legado sem suporte em um controlador porque o software do fornecedor não é certificado para plataformas mais novas. O controlador deve se comunicar apenas com uma estação de engenharia específica. Qual controle reduz melhor o risco de movimento lateral a partir da rede corporativa?

A) Ingressar o controlador no domínio Active Directory corporativo para autenticação centralizada.

B) Colocar o controlador em um segmento de rede separado com regras de firewall permitindo apenas o tráfego necessário para a estação de engenharia.

C) Atribuir ao controlador um endereço IP público para que o fornecedor possa dar suporte remoto sem VPN.

D) Instalar um agente EDR moderno mesmo que o SO legado não o suporte.

QUESTÃO 4 · CENÁRIO DE EXAME

O inventário de ativos de uma organização identifica vários servidores Windows Server 2008 R2 que não recebem mais atualizações de segurança da Microsoft. O aplicativo de negócios neles não tem caminho de atualização suportado ainda, mas é crítico. Qual tratamento de risco é mais apropriado inicialmente?

A) Continuar aplicando as atualizações de segurança mais recentes do Windows manualmente pelo Microsoft Update.

B) Usar o firewall do host como controle permanente e não tomar mais nenhuma ação.

C) Manter os servidores como estão e confiar em varreduras anuais de vulnerabilidade para identificar problemas.

D) Isolar e monitorar os servidores enquanto se planeja a migração ou substituição por um SO suportado.

QUESTÃO 5 · CENÁRIO DE EXAME

Um scanner de vulnerabilidades relata um problema em uma biblioteca do SO. O analista precisa correlacionar a descoberta com avisos de fornecedores, bancos de dados de scanners e feeds de inteligência de ameaças. Qual identificador padronizado o analista deve usar para essa correlação?

A) CVSS

B) CVE

C) CWE

D) MITRE ATT&CK

QUESTÃO 6 · CENÁRIO DE EXAME

Durante uma resposta a incidentes, analistas determinam que um atacante explorou uma vulnerabilidade no kernel do sistema operacional de um servidor Linux. O atacante começou com uma conta de serviço web de baixo privilégio e então obteve controle total do sistema operacional. Qual impacto ocorreu?

A) Negação de serviço

B) Sequestro de sessão

C) Elevação de privilégio

D) Perda de dados por falha de hardware

QUESTÃO 7 · CENÁRIO DE EXAME

Uma amostra de malware fileless explora uma vulnerabilidade recém-divulgada em um serviço do SO. O antivírus tradicional baseado em assinaturas não detecta a atividade porque não existe assinatura de arquivo conhecida. Qual controle é mais adequado para detectar e responder ao comportamento malicioso em endpoints?

A) Criptografia de disco completa

B) Prevenção contra perda de dados

C) Controle de acesso à rede

D) Endpoint Detection and Response

QUESTÃO 8 · CENÁRIO DE EXAME

Um fornecedor lança uma correção emergencial para uma vulnerabilidade crítica explorável remotamente em um serviço do SO. O próximo ciclo mensal de patches é em três semanas, e a vulnerabilidade está sendo explorada ativamente. O que a equipe de gerenciamento de patches deve fazer?

A) Esperar o ciclo mensal de patches para minimizar a interrupção operacional.

B) Usar procedimentos de mudança emergencial para testar e implantar o patch o mais rápido possível, priorizando sistemas expostos.

C) Implantar o patch em todos os sistemas imediatamente, sem testes ou planejamento de rollback.

D) Aplicar o patch somente em sistemas não críticos e deixar servidores críticos sem correção até o ciclo mensal.

QUESTÃO 9 · CENÁRIO DE EXAME

Uma vulnerabilidade crítica é anunciada em um serviço do SO. O patch do fornecedor não pode ser implantado por 48 horas porque testes de compatibilidade são necessários. O serviço vem habilitado por padrão, mas a maioria dos servidores não precisa dele. Qual controle compensatório reduz melhor o risco imediato?

A) Desabilitar o serviço vulnerável onde ele não é necessário e restringi-lo com regras de firewall onde for necessário.

B) Confiar nas assinaturas de antivírus existentes e continuar as operações normais até o patch estar disponível.

C) Alterar todas as senhas de administrador local e continuar as operações normais.

D) Implantar um sistema de prevenção de intrusão baseado em host, mas deixar o serviço habilitado em todos os servidores.

QUESTÃO 10 · CENÁRIO DE EXAME

Uma varredura de vulnerabilidades mostra muitos patches de SO ausentes. Uma descoberta é uma vulnerabilidade de kernel em servidores VPN voltados à internet, listada como explorada conhecida. As demais descobertas são problemas locais de elevação de privilégio em estações internas com baixa probabilidade. Qual abordagem de remediação é mais apropriada?

A) Aplicar patches nos sistemas em ordem alfabética para garantir progresso consistente.

B) Adiar todos os patches até a janela anual de manutenção para reduzir o risco de mudança.

C) Priorizar a vulnerabilidade de kernel explorada conhecida nos servidores VPN voltados à internet e aplicar controles compensatórios até o patch.

D) Aplicar patches somente nas estações internas porque há mais delas.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Aplicar atualizações de segurança do SO Microsoft na segunda terça-feira de cada mês após validá-las em um grupo de teste.

A Microsoft libera a maioria das atualizações de segurança do Windows na Patch Tuesday, a segunda terça-feira de cada mês. Um ciclo mensal controlado com testes equilibra previsibilidade e redução de risco. Esperar a publicação de CVE, permitir adiamento indefinido pelos usuários ou aplicar patches somente em sistemas comprometidos deixa vulnerabilidades conhecidas exploráveis.

Questão 2: Alternativa C — Habilitar detecção comportamental via EDR e implantar controles compensatórios, como hardening e restrições de rede.

Não há patch do fornecedor para uma zero-day, então controles compensatórios e detecção comportamental são apropriados. O EDR pode identificar comportamento de exploração e bloquear ou conter ameaças. Esperar deixa os sistemas expostos; desabilitar módulo sem testes pode causar indisponibilidade; reinstalar todos os sistemas é disruptivo e não direcionado.

Questão 3: Alternativa B — Colocar o controlador em um segmento de rede separado com regras de firewall permitindo apenas o tráfego necessário para a estação de engenharia.

A segmentação limita o movimento lateral ao restringir quais sistemas podem se comunicar com o SO legado. Uma VLAN dedicada e regras de firewall de menor privilégio reduzem a exposição. Ingressar no domínio corporativo amplia a superfície de ataque; IP público expõe o sistema; EDR não suportado não pode ser instalado ou considerado confiável.

Questão 4: Alternativa D — Isolar e monitorar os servidores enquanto se planeja a migração ou substituição por um SO suportado.

Um SO em fim de vida (EOL) não recebe mais patches de segurança do fornecedor, então a correção de longo prazo é migrar ou substituir. No interim, isolamento e monitoramento aprimorado reduzem a exposição. Continuar atualizações não é possível; firewall do host sozinho é insuficiente; varreduras anuais não substituem correção tempestiva.

Questão 5: Alternativa B — CVE

O CVE fornece um identificador único para uma vulnerabilidade pública específica, permitindo correlação entre scanners, avisos de fornecedores e inteligência de ameaças. CVSS é uma pontuação de gravidade, CWE classifica tipos de fraqueza e MITRE ATT&CK descreve táticas e técnicas de adversários.

Questão 6: Alternativa C — Elevação de privilégio

Vulnerabilidades de kernel podem permitir que atacantes cruzem limites de privilégio e obtenham controle em nível root/SYSTEM. Passar de uma conta de baixo privilégio para controle total do SO é elevação de privilégio. DoS, sequestro de sessão ou falha de hardware são categorias de impacto diferentes.

Questão 7: Alternativa D — Endpoint Detection and Response

O EDR coleta telemetria de endpoint e usa análise comportamental para detectar atividades suspeitas em processos, memória e sistema, incluindo exploits fileless e zero-day. DLP foca exfiltração de dados, NAC controla admissão na rede e criptografia de disco protege dados em repouso.

Questão 8: Alternativa B — Usar procedimentos de mudança emergencial para testar e implantar o patch o mais rápido possível, priorizando sistemas expostos.

Patches emergenciais fora do ciclo são justificados para vulnerabilidades críticas exploradas ativamente. Um processo de mudança emergencial deve incluir testes acelerados, planejamento de rollback e priorização de sistemas voltados à internet ou de alto valor. Esperar aumenta a exposição; implantar sem qualquer teste ou rollback é arriscado; deixar sistemas críticos sem correção é inadequado.

Questão 9: Alternativa A — Desabilitar o serviço vulnerável onde ele não é necessário e restringi-lo com regras de firewall onde for necessário.

Reduzir a superfície de ataque desabilitando serviços desnecessários e restringindo o acesso necessário limita oportunidades de exploração até que o patch seja possível. Confiar apenas em antivírus não corrige a falha; alterar senhas isoladamente não corrige o serviço; manter o serviço habilitado em todos os servidores mantém exposição desnecessária.

Questão 10: Alternativa C — Priorizar a vulnerabilidade de kernel explorada conhecida nos servidores VPN voltados à internet e aplicar controles compensatórios até o patch.

A aplicação de patches baseada em risco prioriza vulnerabilidades conforme explorabilidade, exposição e impacto. Uma falha de kernel explorada conhecida em sistemas voltados à internet representa o maior risco imediato. Ordem alfabética, atraso anual ou patch por quantidade ignoram o risco.